

DevShield SaaS - Base de Conocimiento Oficial

Versión 2.4 - Julio de 2026. Documentación técnica, comercial y legal. Documento ficticio con fines educativos.

1. Arquitectura general y back-end

DevShield SaaS es una plataforma en la nube para la **detección automatizada de vulnerabilidades web**: Inyección SQL (SQLi) mediante análisis estático (SAST) y dinámico (DAST), Cross-Site Scripting (XSS) reflejado, almacenado y basado en DOM, y escaneo de repositorios Git (GitHub, GitLab y Bitbucket) para detectar secretos expuestos, dependencias vulnerables (CVE) y configuraciones inseguras.

La plataforma usa una **arquitectura de microservicios** sobre Kubernetes:

- **API Gateway (Python 3.12 + FastAPI)**: recibe solicitudes, autentica con JWT (expiración de 24 horas) y encola trabajos en RabbitMQ.
- **Motor de escaneo (Java 21 + Spring Boot)**: ejecuta cada análisis dentro de un **contenedor Docker aislado y efímero** (sandbox) sin acceso a la red interna, que se destruye al finalizar. El código de un cliente jamás comparte entorno con el de otro.
- **PostgreSQL 16**: resultados, usuarios y facturación; reportes cifrados en reposo con AES-256.
- **Redis**: sesiones y resultados intermedios con TTL de 15 minutos.
- **Panel web (React + TypeScript)**: dashboard con reportes descargables en PDF y JSON.

Toda la comunicación entre servicios viaja cifrada con **TLS 1.3**. Regiones disponibles: us-east, eu-west y sa-east (São Paulo).

1.1 Ciclo de vida de un escaneo

- El usuario registra la URL o conecta su repositorio mediante OAuth.
- El API Gateway valida la propiedad del dominio o repositorio (archivo de verificación o registro DNS TXT).
- El trabajo entra a la cola y un contenedor Docker aislado ejecuta el análisis.
- El motor Java genera el reporte con severidades Crítica, Alta, Media, Baja e Informativa, según el estándar CVSS 3.1.
- El contenedor se destruye y el reporte cifrado queda disponible en el dashboard.

Duración promedio: **8 a 12 minutos** para aplicaciones medianas (hasta 200 endpoints) y **3 a 5 minutos** para repositorios de hasta 500 MB.

2. Planes de suscripción y precios

Característica	Free	Pro	Enterprise
Precio mensual	US\$ 0	US\$ 49	US\$ 299
Escaneos web por mes	5	100	Ilimitados
Repositorios conectados	1	10	Ilimitados
Tamaño máx. por repositorio	100 MB	500 MB	5 GB
Escaneos simultáneos	1	3	10
Detección SQLi y XSS	Sí	Sí	Sí
Detección de secretos en código	No	Sí	Sí
Reportes	Solo PDF	PDF y JSON	PDF, JSON y API
Retención de reportes	30 días	12 meses	24 meses
Usuarios por cuenta	1	5	Ilimitados
Soporte	Foro comunidad	Correo (24 h hábiles)	Prioritario 24/7
API CI/CD	No	1.000 llamadas/mes	Ilimitada

- El plan **Pro anual** tiene 20 % de descuento (US\$ 470/año). Los escaneos no utilizados **no se acumulan** para el mes siguiente.
- El plan **Enterprise** incluye región dedicada opcional y firma de DPA personalizado.

2.1 Preguntas frecuentes (FAQ)

- **¿Puedo cambiar de plan?** Sí: los upgrades se aplican de inmediato con cobro prorrateado; los downgrades, al inicio del siguiente ciclo de facturación.
- **¿Qué pasa si supero mi límite de escaneos?** El escaneo se bloquea; en Pro y Enterprise se pueden comprar 10 escaneos adicionales por US\$ 9.
- **¿DevShield modifica mi código o mi aplicación?** No: todos los análisis son de solo lectura y las pruebas DAST usan cargas útiles seguras.
- **¿Cómo restablezco mi contraseña?** Con la opción 'Olvidé mi contraseña'; el enlace expira en 30 minutos.
- **¿Hay prueba gratuita del plan Pro?** Sí, 14 días sin tarjeta de crédito; al terminar, la cuenta pasa automáticamente al plan Free.

2.2 Acuerdos de Nivel de Servicio (SLA)

- **Disponibilidad garantizada:** 99,5 % mensual (Free y Pro) y **99,9 % (Enterprise)**.
- **Créditos por incumplimiento** (solo planes de pago): entre 99,0 % y el objetivo: 10 % de crédito; entre 95,0 % y 98,99 %: 25 %; menor a 95,0 %: 50 %. Deben solicitarse dentro de los 30 días posteriores al incidente escribiendo a sla@devshield.io.
- **Primera respuesta de soporte:** Free: sin garantía (foro). Pro: 24 horas hábiles. Enterprise: 1 hora para incidentes críticos (P1) y 4 horas para P2.
- El mantenimiento programado se anuncia con 72 horas de antelación y no computa como downtime.

3. Términos de uso

- **Autorización obligatoria:** solo se pueden escanear aplicaciones, dominios y repositorios **propios o con autorización expresa y por escrito** del titular. Queda **estrictamente prohibido** escanear activos de terceros sin consentimiento. La verificación de propiedad (DNS TXT o archivo en el servidor) es requisito previo a todo escaneo web.
- **Sanciones:** el primer intento de escaneo no autorizado suspende la cuenta por 30 días; la reincidencia implica el cierre definitivo sin reembolso y, cuando la ley lo exija, la notificación a las autoridades competentes.
- **Uso aceptable:** prohibido revender el servicio, hacer ingeniería inversa de la plataforma o usar los reportes para atacar sistemas de terceros.
- **Responsabilidad:** DevShield no garantiza detectar el 100 % de las vulnerabilidades. Su responsabilidad total se limita al monto pagado por el cliente en los 12 meses anteriores al reclamo.
- **Cancelación:** disponible en cualquier momento desde el panel; no hay reembolsos por periodos parciales, salvo lo dispuesto en el SLA.

3.1 Política de privacidad y manejo del código fuente

- **Propiedad del código:** el código fuente es y seguirá siendo **propiedad exclusiva del cliente**; DevShield no adquiere ningún derecho sobre él.
- **Procesamiento efímero:** el código clonado vive solo dentro del contenedor Docker aislado y **se elimina de forma irreversible al terminar el análisis** (máximo 60 minutos después). Nunca se almacenan copias permanentes del código; solo persisten los reportes.
- **Confidencialidad:** los empleados de DevShield no acceden al código del cliente, salvo solicitud de soporte autorizada por escrito por el cliente y siempre bajo NDA.
- **Datos personales:** solo se recopilan nombre, correo electrónico y datos de facturación. Nunca se venden datos a terceros. Cumplimiento de GDPR (UE) y LGPD (Brasil). Los pagos los procesa un proveedor certificado PCI-DSS; DevShield no almacena números de tarjeta.
- **Derechos del usuario:** acceso, rectificación y supresión escribiendo a privacy@devshield.io; respuesta en máximo 15 días hábiles.
- **Eliminación de cuenta:** reportes y datos personales se borran definitivamente en 30 días, salvo la obligación legal de retener datos de facturación durante 5 años.

(c) 2026 DevShield Inc. - Documento ficticio creado con fines educativos para el proyecto de Agente Inteligente RAG.